

Clase 166 — Phishing y entrega de payloads

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Operator Handbook (T. Bryant) / MITRE ATT&CK Phishing (T1566)* 🕒 Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Diseñar y ejecutar campañas de phishing controladas como vector de acceso inicial: pretextos creíbles, infraestructura de correo con buena reputación, y payloads que superen los filtros sin quemar la operación. El alumno aprenderá los formatos de entrega modernos (contenedores ISO/LNK, macros, HTML smuggling) y cómo medir la campaña sin dañar a las personas objetivo.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diseñar** un pretexto de phishing y su narrativa coherente.
2. **Configurar** infraestructura de correo (SPF/DKIM/DMARC, dominio calentado) en un lab.
3. **Elegir** el formato de entrega adecuado según el defensor (LNK, ISO, HTML smuggling, macro).
4. **Operar** GoPhish para ejecutar y medir una campaña controlada.
5. **Aplicar** consideraciones éticas y de mínimo daño en el objetivo humano.

Temas

#	Tema	Por qué importa
1	Spear phishing vs masivo	Precisión vs alcance
2	Pretexto y OSINT	La credibilidad decide el clic
3	Reputación de correo	SPF/DKIM/DMARC y dominios calentados
4	Formatos de entrega	Mark-of-the-Web, contenedores, smuggling
5	Landing pages y captura	Robo de credenciales controlado
6	GoPhish	Ejecución y métricas de campaña
7	Ética y salud del objetivo	No dañar a las personas

Definiciones y características

- **Spear phishing (T1566.001)**: correo dirigido con adjunto/enlace a personas concretas. Característica: alta tasa de éxito por personalización.
- **Pretexto**: historia que motiva la acción (factura, RRHH, IT). Característica: debe ser coherente con OSINT del objetivo.
- **Mark-of-the-Web (MOTW)**: marca que Windows pone a archivos de internet. Característica: dispara advertencias; los contenedores (ISO) la evaden.

- **HTML smuggling:** reconstruir el payload en el navegador vía JS/Blob para evadir proxies. Característica: el binario no viaja por la red como tal.
- **SPF/DKIM/DMARC:** mecanismos de autenticación de correo. Característica: bien configurados mejoran la entregabilidad del phishing legítimo del ejercicio.
- **Landing page:** página que captura credenciales o entrega el payload. Característica: clona un servicio conocido de forma controlada.

Herramientas y preparación

- **GoPhish** para gestionar la campaña y métricas.
- Un dominio de práctica con registros SPF/DKIM/DMARC configurados (en tu lab o dominio propio).
- El C2 de las clases anteriores para el payload de la landing.
- Herramientas de generación de contenedores/LNK en un entorno controlado.
- Buzones de "víctima" de laboratorio (cuentas de prueba que tú controlas).

 **Ética reforzada.** El phishing se ejecuta solo contra buzones de laboratorio propios o contra objetivos con autorización escrita y dentro de las RoE. Nunca uses pretextos que causen daño psicológico real (despidos falsos, emergencias familiares). En engagements reales, coordina con la white cell y respeta la dignidad de las personas objetivo.

Laboratorio guiado

1. **OSINT del objetivo ficticio.** Reúne (de fuentes públicas del lab) nombres, roles y el estilo de correo de "ACME Corp".
2. **Monta GoPhish.** Descarga y ejecuta el binario; crea un *Sending Profile* con tu servidor SMTP de lab.
3. **Configura reputación.** Añade SPF, DKIM y DMARC al dominio de práctica y verifica con `dig TXT` que resuelven.
4. **Redacta el pretexto.** Un correo de "actualización de portal de RRHH" con enlace a tu landing; cuida gramática, firma y coherencia.
5. **Crea la landing page.** Clona (en tu lab) la pantalla de login del "portal" y captura credenciales o entrega el payload C2.
6. **Elige la entrega.** Compara enviar un `.lnk` dentro de un `.iso` (evade MOTW) frente a HTML smuggling; documenta pros/cons de cada uno.
7. **Lanza y mide.** Envía a los buzones de laboratorio; en GoPhish observa tasas de apertura, clic y envío de credenciales. Limpia al terminar.

Ejercicios

1. Redacta dos pretextos distintos y evalúa cuál es más creíble y por qué.
2. Configura SPF/DKIM/DMARC en un dominio de prueba y valídalos.
3. Explica cómo un contenedor ISO evade el Mark-of-the-Web.
4. Describe el flujo de HTML smuggling paso a paso.
5. Crea una campaña en GoPhish y explica cada métrica que reporta.
6. Propón 3 reglas éticas propias para campañas contra personas reales.

Reto verificable

Ejecuta una **campaña de phishing completa en tu laboratorio** con GoPhish: pretexto, correo autenticado (SPF/DKIM), landing page y método de entrega que evada MOTW, midiendo apertura y clic. **Criterio de aceptación:** GoPhish reporta al menos un clic desde un buzón de lab, el correo pasa autenticación (no cae en spam por SPF/DKIM), y documentas por qué el método de entrega elegido evade una advertencia de Windows. Todo sobre buzones que controlas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El correo cae en spam	SPF/DKIM/DMARC mal configurados o dominio sin calentar; corrige registros
Windows advierte "archivo de internet"	MOTW en el adjunto; usa contenedor ISO/VHD o smuggling
El pretexto no genera clics	Poco creíble o mal segmentado; mejora OSINT y narrativa
El proxy bloquea la descarga	Payload visible en la red; usa HTML smuggling
Daño real a una persona	Pretexto abusivo; revisa la ética y coordina con la white cell

Preguntas frecuentes

 **¿El phishing sigue siendo el vector #1?** Sí; sigue siendo de los accesos iniciales más efectivos y baratos, por eso es central en la emulación de casi cualquier actor.

 **¿Las macros de Office todavía funcionan?** Cada vez menos: Microsoft bloquea macros de internet por defecto. Hoy dominan LNK en contenedores, HTML smuggling y abuso de instaladores.

 **¿Cómo evito dañar a las personas?** Pretextos neutros, coordinación con la white cell, no explotar emociones sensibles y una fase de concienciación posterior en lugar de señalar culpables.

Referencias

- MITRE ATT&CK — *Phishing* (T1566). <https://attack.mitre.org/techniques/T1566/>
- GoPhish. <https://getgophish.com/> · <https://docs.getgophish.com/>
- Outflank / research sobre *HTML smuggling* y contenedores.
- Bryant, T. — *Operator Handbook*.

Siguiente clase

Clase 167 - Acceso inicial: tecnicas